EXOS AEROSPACE SYSTEMS & TECHNOLOGIES, INC.

PLAN-ROLESAR

Version 1

Generated August 13, 2026

Confidential — Internal Use Only

Table of Contents

1. Purpose
2. User Responsibilities
3. Company Admin Responsibilities
4. Security Admin Responsibilities
5. Compliance Admin Responsibilities
6. Collaboration Across Roles
7. Documentation and Review

PLAN-ROLESAR

1. Purpose

This document outlines the specific functions and responsibilities of Users, Company Admins, Security Admins, and Compliance Admins as per the policies and procedures defined in organizational policies, including SOPs for onboarding, risk management, training, incident response, and other compliance-related activities. This document helps inform the functions defined in the RACI Matrix document.

2. User Responsibilities

Users include all employees, contractors, and third-party personnel with access to the organization's systems or data. Their primary role is to adhere to organizational policies and use systems responsibly.

Key Functions:

1. **System Access and Use:**
   - Use authorized credentials to access systems.
   - Adhere to least privilege principles; do not attempt to access unauthorized resources.
   - Report suspicious activities or unauthorized access immediately.
2. **Training:**
   - Complete mandatory initial and annual cybersecurity training, including CUI handling and insider threat awareness.
   - Participate in role-specific and incident-driven training as required.
3. **System Flaws:**

   Report System Flaws to the *Security Admin* and work with the *Security Admin* to help resolve it as applicable.
4. **Incident Reporting:**

   Report phishing attempts, malware, or other suspicious activities to the *Security Admin* promptly.

   Notify the *Company Admin* of any lost or compromised devices or credentials.
5. **Compliance with Policies:**
   - Follow organizational guidelines for data handling, encryption, and secure communication.
   - Use only approved tools and methods for sharing sensitive information.
6. **Device Management:**
   - Maintain physical and logical security of assigned devices.
   - Use encryption for portable media and avoid unauthorized data storage.

3. Company Admin Responsibilities

The Company Admin oversees organizational compliance, operational efficiency, and the enforcement of security policies. This role involves strategic decision-making and direct oversight of compliance-related activities.

Key Functions:

1. **Policy Enforcement:**
   - Ensure adherence to NIST 800-171, DFARS 7012, and CMMC 2.0 Level 2 requirements across the organization.
   - Approve SOPs, training materials, and procedural updates.
2. **Access Management:**
   - Approve new user onboarding requests, including role assignments.
   - Review and update user privileges based on least privilege principles.
   - Oversee and coordinate the setup of existing devices being transferred to a new user, ensuring the device is properly reconfigured and handed over.
3. **Incident Oversight:**
   - Coordinate responses to security incidents and ensure proper documentation and reporting.
   - Approve containment, mitigation, and recovery strategies during incidents.
4. **Risk Management:**
   - Approve risk response strategies, including mitigation and acceptance decisions.
5. **Training and Awareness:**
   - Approve Training Plan.
6. **Audit and Compliance:**
   - Conduct regular audits of organizational practices to ensure compliance with policies.

4. Security Admin Responsibilities

The Security Admin ensures the implementation of technical controls, system security, and monitoring of organizational compliance with cybersecurity best practices.

Key Functions:

1. **System Security:**
   - Configure and maintain systems to align with security policies, including encryption, access controls, and monitoring.
   -

Regularly update and patch systems to mitigate vulnerabilities.

- Conduct quarterly reviews of authorized user and device access.

2. **Monitoring and Detection:**
   - Use Atomus tools to monitor systems for anomalies and potential threats.
   - Investigate alerts and assess risks to organizational assets.
3. **Risk Assessment and Mitigation:**
   - Conduct regular reviews of the Risk Register and ensure risks are documented and addressed
   - Implement mitigation measures, such as firewall rules, encryption, or role-based access.
   - Create and configure Entra ID user accounts when an existing device is transferred to a new user, provided sufficient licenses are available in the tenant.
4. **Incident Response:**
   - Lead the technical response to incidents, including containment, eradication, and recovery.
   - Document all actions taken during an incident and participate in post-incident reviews.
5. **Training Support:**
   - Oversee training program implementation, ensuring all users complete mandatory training.
   - Provide technical input for cybersecurity and role-specific training programs.
   - Conduct simulated phishing and incident response exercises to enhance user awareness.
   - Review training effectiveness and make improvements as needed.
6. **Compliance Monitoring:**
   - Ensure systems and processes meet regulatory requirements.

   Collaborate with the *Company Admin* to review audit logs, access control mechanisms, and training records.
7. **Maintenance:**
   - Perform remote maintenance sessions with users to resolve IT issues using attended access only; the end-user must be present and authorize each session.
   - Supervise non-local maintenance sessions to ensure they are conducted securely and within approved scope.

5. Compliance Admin Responsibilities

The Compliance Admin oversees organizational compliance with NIST SP 800-171, DFARS 7012, and CMMC requirements. This role manages compliance documentation, evidence, and control implementation tracking, and primarily collaborates with the Company Admin, and Security Admin to ensure assessment readiness. The Compliance Admin does not access or configure systems directly, instead

they provide oversight and coordination to ensure required security and compliance measures are properly implemented as per requirements.

Key Functions:

1. **Documentation and Evidence Management:**
   - Maintain and update documents - SSP, and POA&M.
   - Build, Review and Maintain Policies, Procedures and Plans.

   Organize and update compliance evidence, registers, asset inventories, and related compliance records with help from *Security Admin* and *Company Admin*.

2. **Compliance Reviews and Oversight:**

   Conduct quarterly reviews with the *Security Admin* including access reviews, vulnerability documentation, audit log checks, and related compliance tasks.

   - Monitor compliance items in the portal, identify gaps, and coordinate updates with responsible roles.

   Review technical evidence provided by the *Security Admin* and determine if it meets compliance requirements.

3. **Audit and Questionnaire Support:**
   - Prepare and organize documentation and evidence needed for audits or assessments.

   Lead audit discussions related to compliance processes and documentation, with *Security Admin* support for technical demonstrations.

   Complete compliance questionnaires and other requests provided by the *Company Admin*, gathering technical details from the *Security Admin* as necessary.

4. **Risk and Incident Documentation:**
   - Manage the Risk Register and ensure risks are documented and advise on mitigation methods.
   - Oversee incident documentation by capturing timelines, reporting elements, and compliance-related evidence.

   Coordinate with the *Security Admin* to obtain required technical details and ensure incident records are complete.

6. Collaboration Across Roles

Users:

- Report incidents and complete training.
- Comply with all policies to minimize organizational risk.

Company Admin:

- Set the strategic direction for security and compliance.
- Ensure proper oversight and enforcement of all policies.

Security Admin:

- Implement technical controls and respond to risks.

Collaborate with the *Company Admin* to monitor and enhance security practices.

Compliance Admin:

Coordinate with *Security Admin* to ensure device configurations align with policy requirements.

7. Documentation and Review

- All roles must document their activities as outlined in relevant SOPs.
- This document will be reviewed annually or after significant organizational or regulatory changes.

For questions or further clarification, contact your *Company Admin*.

Revision History

Version	Date	Author	Change Summary
v1	Aug 11, 2026	nathaniel@atomus-cyber.com	Initial publication of "PLAN-ROLESAR".

Acknowledgement & Signature

By signing below, the undersigned acknowledges that the contents of PLAN-ROLESAR (Version 1) have been reviewed and approved on behalf of Exos Aerospace Systems & Technologies, Inc..

Point of Contact

NAME

Jquinn

TITLE

Chief Executive Officer, Co-Founder

SIGNATURE

DATE

Aug 13, 2026

Signed electronically on Aug 13, 2026